CASE STUDY

The BeyondTrust Remote Support and PRA Command Injection of 2026 (CVE-2026-1731): A Case Study

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

The people on the hook here were the help-desk and privileged-access teams who run BeyondTrust Remote Support (RS) and Privileged Remote Access (PRA) on their own appliances. In the first week of February 2026 they learned that anyone who could reach the appliance could run operating-system commands on it as the site user, without logging in [1] [2] (**Confirmed**). Customers on BeyondTrust's cloud service did not have to do anything: the vendor patched every SaaS tenant on 2 February, four days before it published the advisory [1] (**Confirmed**).

Self-hosted customers who had not patched were the ones exposed. BeyondTrust saw its first exploitation attempt on 10 February [1], and CISA added the flaw to the Known Exploited Vulnerabilities (KEV) catalog on 13 February with a three-day deadline [5] [6] (**Confirmed**). Within a week of disclosure, Google's threat intelligence group counted six threat clusters exploiting the bug [15]. Responders described new domain administrators, remote-management tools, web shells and data theft in activity they tie to exploitation (Arctic Wolf calls it suspected) [13] [14] (**Reported**). By August the FBI, CISA and HHS listed CVE-2026-1731 among the flaws the Medusa ransomware operation exploits [17] (**Confirmed**).

Key facts at a glance

Field	Value
Products	BeyondTrust Remote Support (RS) and certain older Privileged Remote Access (PRA) versions [1] [2]
Flaw	Pre-authentication OS command injection running as the site user; CWE-78; CNA CVSS 4.0 9.9; NVD CVSS 3.1 9.8 [2] [3]
Affected	RS 25.3.1 and earlier; PRA 24.3.4 and earlier [1] [2]
Fixed	Patch BT26-02-RS (RS 21.3 to 25.3.1) or RS 25.3.2 and later; patch BT26-02-PRA (PRA 22.1 to 24.x) or PRA 25.1.1 or later (the advisory's table lists 25.1 and greater) [1]
Disclosed	Advisory BT26-02 and CVE, 6 Feb 2026; CVE reserved 31 Jan 2026 [1] [2]
SaaS patched	2 Feb 2026, automatically [1]
First exploitation attempt	10 Feb 2026, per BeyondTrust [1]
KEV	Added 13 Feb 2026, due 16 Feb; ransomware use now Known [5] [6]
Named actor	Medusa, in FBI, CISA and HHS advisory AA25-071A (updated 18 Aug 2026) [17]
Exposure estimates	About 11,000 RS instances, about 8,500 on-premises (Hacktron); more than 16,400 potentially vulnerable (Unit 42) [8] [14]

Key findings

- **Automatic updates decided who was hurt.** SaaS tenants and appliances with the update service on were patched on 2 February, eight days before the first exploitation attempt the vendor records. BeyondTrust says the exploitation it has seen is limited to internet-facing self-hosted instances not patched before 9 February [1] (**Confirmed**; the conclusion is **Inferred**).
- **This was a repeat.** CVE-2024-12356, an unauthenticated command injection in the same products, entered KEV in December 2024 [6] [19] (**Confirmed**). GreyNoise calls the 2026 bug a variant of it [10], Unit 42 treats the two as a recurring input-validation problem in different code paths [14], and the discoverer says it found the flaw through variant analysis [8] (**Reported**).
- **The crowd arrived fast.** GreyNoise saw reconnaissance surge on 11 February, within a day of a public proof of concept [10], and Google saw six clusters exploiting the flaw within seven days of disclosure [15] (**Reported**).
- **Ransomware is named, but loosely.** KEV now marks ransomware use as Known [6], and AA25-071A names Medusa [17] (**Confirmed**). The KEV record names no ransomware family [6] (**Confirmed**), and no source opened ties a specific Medusa intrusion to this CVE (**Inferred**).
- **Attribution to a state actor goes beyond the record.** No source opened attributes the 2026 exploitation of CVE-2026-1731 to a state actor; the state-actor names attach to the 2024 incident [10] [14] (**Inferred**).

Top recommendations

1. Confirm every self-hosted RS and PRA appliance runs RS 25.3.2 or later, PRA 25.1.1 or later (the advisory's table lists 25.1 and greater), or the BT26-02 patch, and upgrade RS older than 21.3 and PRA older than 22.1 before patching [1] (**Confirmed** as the vendor's guidance).
2. Keep the appliance update service on; it is the control that separated patched from exposed in this record [1] (**Inferred**).
3. Treat any internet-facing self-hosted instance not patched by 9 February 2026 as possibly compromised: check it for signs of compromise as the KEV notes direct, and open a Severity 1 ticket citing BT26-02 [1] [6] (**Confirmed** as vendor and CISA guidance).
4. Hunt for new domain or local administrator accounts, remote-management tools started by appliance processes, PsExec fan-out, Active Directory enumeration, out-of-band DNS lookups and web shells on the appliance [13] [14] (**Reported**).
5. Patch CVE-2026-102764 as well; it is a separate, later RS flaw that entered KEV on 16 October 2026 [6] [16] (**Confirmed**).

Scope and method

This brief covers CVE-2026-1731 from BeyondTrust's 2024 precedent to the KEV catalog of 10 November 2026, with CVE-2026-102764 as later context. It does not repeat the China-nexus history in Threat Actors: China or the Medusa profiles in the Healthcare Threat Watchlist [24] and The Ransomware Ecosystem. Tradecraft is described at advisory level; no exploit detail is reproduced, and the public proof-of-concept repository is cited without a link.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: BeyondTrust's advisories and investigation page, the CVE, NVD and KEV records, CISA and FBI advisories, the Treasury release, the Intelligence Hub data and the library's own files
Reported	Stated by the discoverer or a named research firm (Hacktron, GreyNoise, Arctic Wolf, Unit 42, Google Threat Intelligence Group) and not confirmed in a primary
Demonstrated	A research proof of concept or a fixed vulnerability with no known in-the-wild use; no claim in this study carries this grade
Inferred	This study's own reasoning from cited facts, labelled where it appears

All sources were opened on 11 November 2026. BeyondTrust's 3 February knowledge article is behind a customer login, its BT26-05 advisory returned an error, and Treasury's December 2024 letter to Congress was not opened; facts that depend on them are attributed to the sources that report them.

Part 1: what happened

Date	Event	Sources	Grade
5 Dec 2024	BeyondTrust confirms a stolen RS SaaS infrastructure API key, taken through a third-party application zero-day in a BeyondTrust AWS account, was used to reset local passwords on 17 RS SaaS customer instances	[18]	Confirmed
13 Dec 2024	CVE-2024-12356 and CVE-2024-12686 found during that investigation	[18]	Confirmed
16 Dec 2024	Advisory BT24-10 discloses CVE-2024-12356, a critical unauthenticated command injection in RS and PRA	[19]	Confirmed
19 Dec 2024	KEV adds CVE-2024-12356; law enforcement attributes the incident to China-nexus actors	[6] [18]	Confirmed
13 Jan 2025	KEV adds CVE-2024-12686, an OS command injection that needs admin rights	[6]	Confirmed
17 Jan 2025	BeyondTrust closes its investigation; OFAC sanctions Yin Kecheng, whom it associates with the Treasury Departmental Offices compromise	[18] [20]	Confirmed
5 Jan 2026	GreyNoise records activity using the older BeyondTrust exploit chain	[10]	Reported
31 Jan 2026	BeyondTrust detects anomalous activity on a single RS appliance; Hacktron reports the flaw and BeyondTrust confirms it the same day; CVE reserved at 23:54 UTC	[1] [2] [8] [9]	Confirmed; Hacktron Reported
2 Feb 2026	Patches BT26-02-RS and BT26-02-PRA issued and pushed to every instance with the update service on; RS and PRA SaaS fully patched	[1]	Confirmed
3 Feb 2026	Knowledge article posted on the customer portal	[1]	Confirmed
4 Feb 2026	Email to unpatched self-hosted customers	[1]	Confirmed
6 Feb 2026	Advisory BT26-02 and CVE published (CVE record 21:49 UTC; NVD received 22:16 UTC); further customer email; Hacktron publishes without technical detail	[1] [2] [4] [9]	Confirmed
9 Feb 2026	Arctic Wolf has seen no exploitation and no public proof of concept; the vendor later uses this date as its cut-off for exposed instances	[1] [12]	Reported; Confirmed
10 Feb 2026	BeyondTrust records its first observed exploitation attempt and emails customers again; GreyNoise says a proof of concept was posted to GitHub	[1] [10]	Confirmed; Reported
11 Feb 2026	Public repository win3zz/CVE-2026-1731 created at 09:18:33 UTC; reconnaissance surges	[10] [11]	Confirmed; Reported
10 to 13 Feb 2026	Google sees one cluster exploiting the flaw within four days of disclosure and six within seven days	[15]	Reported

Date	Event	Sources	Grade
13 Feb 2026	KEV adds CVE-2026-1731, due 16 Feb; BT26-02 updated; Arctic Wolf reports suspected exploitation; NVD adds the proof-of-concept repository as a reference	[1] [4] [5] [6] [13]	Confirmed; Arctic Wolf Reported
14 Feb 2026	CISA-ADP decision: exploitation active, automatable, total technical impact	[2]	Confirmed
17 Feb 2026	NVD initial analysis adds CVSS 3.1 9.8 and CPE ranges	[4]	Confirmed
18 to 19 Feb 2026	KEV ransomware flag changes from Unknown to Known (cisagov/kev-data commit 8d4e811)	[7]	Confirmed
19 Feb 2026	Unit 42 reports a multi-sector campaign	[14]	Reported
19 May 2026	Unit 42 stops updating its brief	[14]	Reported
18 Aug 2026	AA25-071A update lists CVE-2026-1731 among the flaws Medusa exploits	[17]	Confirmed
Late Aug 2026	ARMORY CASTLE begins zero-day exploitation of a different RS flaw, CVE-2026-102764	[16]	Reported
30 Sep 2026	Google calls the discovery an early indicator of AI-assisted vulnerability discovery	[15]	Reported
9 Oct 2026	SaaS tenants patched for CVE-2026-102764	[16]	Reported
15 to 16 Oct 2026	CVE-2026-102764 disclosed; KEV adds it, due 19 Oct under BOD 26-04	[6] [16]	KEV Confirmed; disclosure date Reported

Discrepancies in the record

- **Two starting points on 31 January.** BeyondTrust's timeline begins with anomalous activity on one customer appliance, which an external researcher then confirmed and reported [1]; Hacktron's begins with its own discovery [8] [9] (**Confirmed**; Hacktron **Reported**). Neither says whether that activity was exploitation before disclosure, so this study does not assert it (**Inferred**).
- **The PRA fixed version.** BT26-02's Fixed Versions table lists Privileged Remote Access 25.1 and greater, but the same advisory's mitigation text tells self-hosted PRA customers they may upgrade to 25.1.1 or a newer version [1] (**Confirmed**), so the inconsistency sits inside the vendor advisory itself. NVD marks PRA versions below 25.1 as vulnerable [3] (**Confirmed**). Hacktron gives the first fixed PRA build as 25.1.1 [8] (**Reported**). PRA 25.1.1 or later is the only version that meets every one of these statements, so it is the one to target (**Inferred**).
- **The proof-of-concept date.** GreyNoise says 10 February [10]; the repository that NVD lists was created on 11 February UTC [11] (**Confirmed**). It may be a different repository or a time-zone difference (**Inferred**).

- **Exposure counts.** Hacktron counted about 11,000 internet-exposed RS instances [8]; Unit 42 counted more than 16,400 that may be vulnerable [14] (**Reported**). The gap most likely reflects different telemetry and scope (**Inferred**).

Part 2: the technical record

CVE	Class and weakness	Score	KEV (catalog 2026.11.10)
CVE-2026-1731	Pre-authentication OS command injection in RS and PRA; CWE-78; CNA lists CAPEC-248	CVSS 4.0 9.9 (AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:L/SI:H/SA:L); NVD CVSS 3.1 9.8	Added 13 Feb 2026, due 16 Feb 2026 [2] [3] [6]
CVE-2024-12356	Unauthenticated command injection in RS and PRA; CWE-77	not checked	Added 19 Dec 2024 [6] [19]
CVE-2024-12686	OS command injection needing admin rights; CWE-78	not checked	Added 13 Jan 2025 [6]
CVE-2026-102764	RS authentication bypass by spoofing; CWE-290; advisory BT26-05	not checked	Added 16 Oct 2026, due 19 Oct 2026 [6]

The mechanism, at advisory level. The CNA describes a critical pre-authentication remote code execution flaw: with specially crafted requests, an unauthenticated remote attacker may run operating-system commands in the context of the site user [2] (**Confirmed**). CISA's decision record calls it automatable with total technical impact [2] (**Confirmed**). Unit 42 says earlier patches for the component reportedly added numeric checks that did not cover every case, and it places the 2024 and 2026 flaws in different execution paths: third-party PostgreSQL handling for CVE-2024-12356 and BeyondTrust's own code for CVE-2026-1731 [14] (**Reported**).

What the attackers did after. In activity it ties to suspected exploitation, Arctic Wolf saw renamed SimpleHelp remote-management binaries started by Bomgar processes as SYSTEM, new domain accounts added to Domain Admins and Enterprise Admins, Active Directory computer discovery, PsExec used to push SimpleHelp, and Impacket SMBv2 session setup early in affected environments, each of which had an appliance confirmed to run a vulnerable version [13] (**Reported**). Unit 42 adds SparkRAT and VShell backdoors, attempted installs of SimpleHelp, AnyDesk and Cloudflare tunnels, PHP web shells in the China Chopper or AntSword style, out-of-band DNS callbacks to confirm code execution, and staging and theft of configuration files and a PostgreSQL dump [14] (**Reported**). Google lists privilege escalation, data exfiltration, SNOWLIGHT, SPARKRAT and cryptominers [15] (**Reported**).

How it was found. BeyondTrust credits Harsh Jaiswal and the Hacktron AI team and says Hacktron found the flaw through AI-enabled variant analysis [1] (**Confirmed**). Google later wrote that Hacktron's research agent found it on its own [15] (**Reported**).

Part 3: who and why

The 2026 exploiters. Arctic Wolf, Unit 42 and Google describe the 2026 activity without naming an actor [13] [14] [15], and GreyNoise does not attribute the reconnaissance. It associates its main scanner with a commercial VPN service hosted by a Frankfurt provider, active in its data since 2023 [10] (**Reported**). Google counted six clusters, named none, and described targeted initial-access campaigns [15] (**Reported**). The mix of payloads, from cryptominers to remote-access tools to data theft, fits several unrelated actors more than a single campaign (**Inferred**).

Medusa. The FBI, CISA and HHS list CVE-2026-1731 among the vulnerabilities Medusa actors exploit [17] (**Confirmed**). The advisory says Medusa watches announcements such as the February 2026 publication of this CVE, uses newly announced exploits within 24 hours, and has used exploits up to a week before disclosure, with no sign that it builds exploits itself [17] (**Confirmed**). The FBI also saw Medusa use BeyondTrust as remote access software, and the advisory's indicator table lists addresses used to access a BeyondTrust session; it does not say those sessions came from exploiting CVE-2026-1731 [17] (**Confirmed**). Among the sources opened, it is the only government source that ties CVE-2026-1731 use to a named actor (**Inferred**).

The 2024 lineage. Law enforcement attributed BeyondTrust's 2024 incident to China-nexus actors [18], and OFAC sanctioned Yin Kecheng, whom it calls MSS-affiliated and associated with the Treasury Departmental Offices compromise [20] (**Confirmed**). Neither the vendor page nor the OFAC release names the other party [18] [20] (**Confirmed**). GreyNoise ties the earlier exploit chain to the December 2024 Treasury breach [10] (**Reported**). Unit 42 says Silk Typhoon, which it equates with APT27, UNC5221 and Emissary Panda, exploited CVE-2024-12356 in that breach [14] (**Reported**). Those names do not line up: ATT&CK files Silk Typhoon under HAFNIUM (G0125) and APT27 under Threat Group-3390 (G0027), and Threat Actors: China records Google's statement that UNC5221 is not Silk Typhoon [23] [24] (**Confirmed**).

The later actor. Google says ARMORY CASTLE (formerly UNC5221) exploited CVE-2026-102764 as a zero-day from late August 2026; its post does not mention CVE-2026-1731 [16] (**Reported**). Threat Actors: China already covers that campaign [24] (**Confirmed**).

Part 4: impact and response

Victims. BeyondTrust says it is supporting "a limited number of self-hosted customers" and gives no count [1] (**Confirmed**). Unit 42 says the campaign hit financial services, legal services, high technology, higher education, wholesale and retail, and healthcare in the United States, France, Germany, Australia and Canada [14] (**Reported**). Hacktron says RS is common in large enterprises, healthcare, financial services, government and hospitality [9] (**Reported**). AA25-071A puts Medusa at over 500 victims as of April 2026, across medical, education, legal, insurance, technology and manufacturing, with healthcare a frequent victim [17] (**Confirmed**). That is Medusa's total, not a count of victims reached through this CVE (**Inferred**).

The vendor. BeyondTrust told customers five times between 3 and 10 February: a portal article on 3 February, emails on 4, 6 and 10 February, and the advisory on 6 February [1] (**Confirmed**). It updated the advisory on 13 February and asks exploited customers to open a Severity 1 ticket citing BT26-02 [1] (**Confirmed**).

CISA and KEV. CISA added CVE-2026-1731 "based on evidence of active exploitation" on 13 February with a due date of 16 February under BOD 22-01 [5] [6] (**Confirmed**). The required action is to apply vendor mitigations, follow BOD 22-01 guidance for cloud services or stop using the product, and the notes ask agencies to check every internet-accessible affected BeyondTrust product for compromise [6] (**Confirmed**). The ransomware flag moved from Unknown to Known between 18 and 19 February [7] (**Confirmed**). The Intelligence Hub carries the KEV row dated 13 February with CVSS 9.9 and CWE-78 in its CVE index and its February monthly report [21] [22] (**Confirmed**).

Part 5: the defender and vulnerability-management view

Remote-support appliances hold standing, trusted paths into the endpoints they manage, so a pre-authentication bug on one reaches far past the appliance (**Inferred**). This record has an unusual shape: the patch existed before the advisory, and the risk sat almost entirely with self-hosted customers who turned off or delayed updates [1] (**Inferred** from the vendor timeline).

Control	Where it meets the record
Keep the vendor update service on for self-hosted appliances	Auto-update instances patched 2 Feb, eight days before the first attempt [1]
Inventory appliances on every port, not only 443	Most probes went to non-standard ports [10]
Count the KEV clock from disclosure, not from KEV	First cluster within four days, KEV after seven [6] [15]
Hunt any instance unpatched by 9 Feb	Vendor scope of observed exploitation; KEV notes [1] [6]
Alert on admin-group changes and new domain accounts	Domain Admins and Enterprise Admins additions [13]
Block or alert on remote-management tools not on the approved list	SimpleHelp and AnyDesk installs started from appliance processes [13] [14]
Watch the appliance file system for web shells and watch outbound DNS	Web shells and out-of-band DNS callbacks [14]
Track the product's KEV history as a whole	Four KEV entries in under two years [6]

What is overstated and what is understated

- **Overstated:** Unit 42's alias chain (Silk Typhoon as APT27, UNC5221 and Emissary Panda) and any reading that the 2024 Treasury actor is behind the 2026 activity go beyond the record; no source opened attributes the 2026 exploitation of CVE-2026-1731 to a state actor [14] [24] (**Inferred**). Google's account that Hacktron's agent found the flaw on its own [15] sits beside a vendor timeline that starts with anomalous activity on a customer appliance, even though BeyondTrust also credits Hacktron's AI-enabled variant analysis [1]; neither source says whether that activity was exploitation (**Inferred**). The KEV ransomware flag names no family, and AA25-071A does not tie a specific Medusa intrusion to this CVE [6] [17] (**Confirmed**).
- **Understated:** BeyondTrust's "limited number" of affected customers sits beside more than 16,400 exposed instances that Unit 42 says are potentially vulnerable [14], six clusters within a week [15] and a ransomware operation named by three agencies [17] (**Reported** and **Confirmed**). With no victim count published, the known incidents are a floor, not a count (**Inferred**).

MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 Enterprise, CWE, CAPEC and D3FEND. Names and tactics come from the library's `data/attack/technique_profiles.jsonl`, `technique_to_d3fend.jsonl`, `superseded_by.jsonl`, `groups.jsonl`, `software.jsonl` and `data/weaknesses/` files [23] (**Confirmed**). No source names ATT&CK technique ids; each row is this study's mapping (**Inferred**). None of the bound ids is revoked [23] (**Confirmed**). Remote-support appliances are not industrial control systems and no source describes an ICS effect, so no ATT&CK for ICS table applies.

Groups, software and campaigns

ATT&CK has no software object for SparkRAT, VShell, SNOWLIGHT or SimpleHelp [23] (**Confirmed**), and no campaign object for this activity [23] (**Confirmed**). ARMORY CASTLE has no ATT&CK object [24] (**Confirmed**).

Object	ATT&CK id	Relationship to this record
Medusa Group	G1051	AA25-071A lists CVE-2026-1731 among the flaws Medusa actors exploit (updated 18 Aug 2026) [17]
Medusa Ransomware	S1244	Medusa's ransomware; no source ties a deployment to this CVE [17]; not S1220 MEDUSA [23]
PsExec	S0029	Used to push SimpleHelp (Arctic Wolf, 13 Feb) [13]
Impacket	S0357	SMB session setup (Arctic Wolf, 13 Feb) [13]
China Chopper	S0020	Style resemblance only: Unit 42 describes PHP web shells in the China Chopper or AntSword style (19 Feb) [14]
HAFNIUM	G0125	Lineage only: ATT&CK's Silk Typhoon alias, named by Unit 42 and GreyNoise for 2024 [10] [14]; not bound to 2026
Threat Group-3390	G0027	Lineage only: ATT&CK's APT27 alias, named by Unit 42 for 2024 [14]; not bound to 2026

ATT&CK Enterprise techniques

ID	Name	Tactic(s)	Dated event or report	Sources
T1595.002	Vulnerability Scanning	Reconnaissance	Reconnaissance surge from 11 Feb (GreyNoise, 12 Feb)	[10]
T1588.005	Exploits	Resource Development	Medusa uses newly announced exploits within 24 hours (AA25-071A, 18 Aug)	[17]
T1190	Exploit Public-Facing Application	Initial Access	First attempt 10 Feb (BeyondTrust); KEV 13 Feb; six clusters (Google, 30 Sep); Medusa (AA25-071A)	[1] [6] [15] [17]
T1505.003	Web Shell	Persistence	PHP web shells (Unit 42, 19 Feb)	[14]
T1136.002	Domain Account	Persistence	New domain accounts (Arctic Wolf, 13 Feb; Unit 42, 19 Feb)	[13] [14]
T1098.007	Additional Local or Domain Groups	Persistence, Privilege Escalation	Accounts added to Domain Admins and Enterprise Admins (Arctic Wolf, 13 Feb)	[13]
T1036.003	Rename Legitimate Utilities	Stealth	Renamed SimpleHelp binaries (Arctic Wolf, 13 Feb)	[13]
T1018	Remote System Discovery	Discovery	Active Directory computer discovery (Arctic Wolf, 13 Feb)	[13]
T1570	Lateral Tool Transfer	Lateral Movement	PsExec used to push SimpleHelp (Arctic Wolf, 13 Feb)	[13]
T1021.002	SMB/Windows Admin Shares	Lateral Movement	Impacket SMB session setup (Arctic Wolf, 13 Feb)	[13]
T1219.002	Remote Desktop Software	Command and Control	SimpleHelp and AnyDesk (Arctic Wolf, 13 Feb; Unit 42, 19 Feb)	[13] [14]
T1572	Protocol Tunneling	Command and Control	Attempted Cloudflare tunnel installs (Unit 42, 19 Feb)	[14]
T1071.004	DNS	Command and Control	Out-of-band DNS callbacks confirming execution (Unit 42, 19 Feb)	[14]
T1005	Data from Local System	Collection	Configuration files and a PostgreSQL dump (Unit 42, 19 Feb)	[14]
T1074.001	Local Data Staging	Collection	Staging before theft (Unit 42, 19 Feb)	[14]
T1496.001	Compute Hijacking	Impact	Cryptominers (Google, 30 Sep)	[15]

Fit notes (**Inferred**): the command execution itself is part of the T1190 exploitation, so no interpreter technique is bound. T1588.005 binds Medusa's general practice as AA25-071A describes it, not a dated act against this CVE. T1071.004 is an inexact fit, because the callbacks confirmed execution rather than carried command traffic. T1219.002 assumes SimpleHelp and AnyDesk were used as remote desktop software. Exfiltration, privilege escalation and the SparkRAT and VShell backdoors are not bound because the sources do not say how they worked.

CWE and CAPEC

CWE	Name	Where it is assigned	Sources
CWE-78	Improper Neutralization of Special Elements used in an OS Command	CVE-2026-1731 (CNA, KEV); CVE-2024-12686 (KEV)	[2] [6]
CWE-77	Improper Neutralization of Special Elements used in a Command	CVE-2024-12356 (KEV)	[6]
CWE-290	Authentication Bypass by Spoofing	CVE-2026-102764 (KEV)	[6]

CAPEC	Name	Via	Where it meets the record
CAPEC-248	Command Injection	The CNA's impact entry; the library relates it to CWE-77	CVE-2026-1731 and its 2024 precedent [2] [6]
CAPEC-88	OS Command Injection	CWE-78	CVE-2026-1731 [2]

The library relates CAPEC-248 to CWE-77 rather than CWE-78, so the CNA's pairing of CWE-78 with CAPEC-248 crosses the two; CAPEC-88 is the entry the library relates to CWE-78 [23] (**Confirmed**). See the CWE Reference and CAPEC Reference.

D3FEND countermeasures

D3FEND countermeasure	Techniques the library maps it to (from this study)	Where it meets the record
Inbound Traffic Filtering, Network Traffic Filtering	T1190	Limiting who can reach the appliance, on every port [10]
Domain Account Monitoring	T1136.002	New domain accounts [13]
Executable Denylisting, Executable Allowlisting	T1036.003	Renamed remote-management binaries [13]
Remote Terminal Session Detection	T1570	PsExec fan-out [13]
File Integrity Monitoring	T1505.003	Web shells on the appliance [14]
DNS Traffic Analysis	T1071.004	Out-of-band DNS callbacks [14]
Outbound Traffic Filtering	T1572, T1071.004	Cloudflare tunnels and DNS callbacks [14]

The control that decided this case, automatic patching, corresponds to Software Update, which the library does not relate to T1190 [1] [23] (**Inferred**). See the D3FEND Reference.

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, `navigator/library-layers/beyondtrust-remote-support-cve-2026-1731.json` (open in Navigator). Scores: 75 for behavior in a vendor advisory, the KEV record or a government advisory, 50 for a vendor threat-intelligence report, 25 for an inexact fit. Each technique's comment names its source numbers.

Cross-cutting themes

- **Remote-access tools are edge devices.** A remote-support appliance faces the internet and holds trusted paths inward, the same pattern the Edge Device Security Reference traces on VPNs and firewalls (**Inferred**).
- **Incomplete fixes come back as variants.** GreyNoise calls the 2026 bug a variant of the 2024 one [10], and Unit 42 describes a recurring input-validation problem across code paths [14] (**Reported**); a product with one KEV entry is worth hunting for siblings (**Inferred**).
- **Machine-assisted discovery cuts both ways.** The same variant analysis that found the bug for the vendor is open to attackers; the library's AI Threats 2026 study covers the wider trend [15] (**Inferred**).
- **Ransomware crews ride other people's disclosures.** Medusa's practice of using new exploits within a day [17] turns every public advisory into a deadline (**Inferred**).

Sources

All sources were opened on 11 November 2026.

#	Source	URL	Opened	Grade
1	BeyondTrust, Security Advisory BT26-02, first published 6 Feb 2026, updated 13 Feb 2026	beyondtrust.com/trust-center/security-advisories/bt26-02	2026-11-11	Confirmed
2	CVE Program record CVE-2026-1731 (CNA BeyondTrust, with the CISA-ADP container), also read through the CVE Services API	cve.org/CVERecord?id=CVE-2026-1731	2026-11-11	Confirmed
3	NVD, CVE-2026-1731	nvd.nist.gov/vuln/detail/CVE-2026-1731	2026-11-11	Confirmed
4	NVD, CVE change history API for CVE-2026-1731	services.nvd.nist.gov/rest/json/cvehistory/2.0?cveId=CVE-2026-1731	2026-11-11	Confirmed
5	CISA, CISA Adds One Known Exploited Vulnerability to Catalog, 13 Feb 2026	cisa.gov/news-events/alerts/2026/02/13/...	2026-11-11	Confirmed
6	CISA, Known Exploited Vulnerabilities catalog JSON, version 2026.11.10	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed
7	cisagov/kev-data, commit 8d4e811, 19 Feb 2026	github.com/cisagov/kev-data/commit/8d4e811...	2026-11-11	Confirmed
8	Hacktron (Harsh Jaiswal and Mohan Pedhapati), CVE-2026-1731 write-up, 6 Feb 2026	hacktron.ai/blog/cve-2026-1731-beyondtrust-remote-support-rce	2026-11-11	Reported
9	Hacktron, Pre-auth RCE in BeyondTrust, 6 Feb 2026	hacktron.ai/blog/beyondtrust-rce	2026-11-11	Reported
10	GreyNoise (Glenn Thorpe), Reconnaissance Has Begun for the New BeyondTrust RCE (CVE-2026-1731), 12 Feb 2026	greynoise.io/blog/reconnaissance-beyondtrust-rce-cve-2026-1731	2026-11-11	Reported
11	GitHub repository metadata for win3zz/CVE-2026-1731 (metadata only; contents not opened; not linked by this study)	not linked	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
12	Arctic Wolf, CVE-2026-1731 bulletin, 9 Feb 2026	arcticwolf.com/resources/blog/cve-2026-1731/	2026-11-11	Reported
13	Arctic Wolf, update on a threat campaign targeting BeyondTrust Remote Support after proof-of-concept availability, 13 Feb 2026	arcticwolf.com/resources/blog/update-arctic-wolf-observes-...	2026-11-11	Reported
14	Unit 42, VShell and SparkRAT Observed in Exploitation of BeyondTrust Critical Vulnerability (CVE-2026-1731), 19 Feb 2026, updates stopped 19 May 2026	unit42.paloaltonetworks.com/beyondtrust-cve-2026-1731/	2026-11-11	Reported
15	Google Threat Intelligence Group, Vulnerability Discovery and Exploitation Trends in the AI Era, 30 Sep 2026	cloud.google.com/blog/topics/threat-intelligence/vulnerability-discovery-...	2026-11-11	Reported
16	Google Threat Intelligence Group, ARMORY CASTLE Exploits BeyondTrust, 15 Oct 2026	cloud.google.com/blog/topics/threat-intelligence/armory-castle-exploits-beyondtrust/	2026-11-11	Reported
17	FBI, CISA and HHS, AA25-071A, #StopRansomware: Medusa Ransomware, 12 Mar 2025, updated 18 Aug 2026	cisa.gov/news-events/cybersecurity-advisories/aa25-071a	2026-11-11	Confirmed
18	BeyondTrust, Remote Support SaaS Service Security Investigation, 8 Dec 2024, updated 28 Jan 2025	beyondtrust.com/remote-support-saas-service-security-investigation	2026-11-11	Confirmed
19	BeyondTrust, Security Advisory BT24-10 (CVE-2024-12356), 16 Dec 2024	beyondtrust.com/trust-center/security-advisories/bt24-10	2026-11-11	Confirmed
20	U.S. Department of the Treasury, press release jy2792 (Yin Kecheng), 17 Jan 2025	home.treasury.gov/news/press-releases/jy2792	2026-11-11	Confirmed
21	Team Star Wolf Intelligence Hub, feed.json (KEV row and CVE index)	teamstarwolf.github.io/intelligence-hub/data/feed.json	2026-11-11	Confirmed
22	Team Star Wolf Intelligence Hub, monthly report 2026-02	github.com/TeamStarWolf/intelligence-hub/.../2026-02/README.md	2026-11-11	Confirmed
23	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `superseded_by.jsonl`, `groups.jsonl`, `software.jsonl`, `campaigns.jsonl`, `technique_to_d3fend.jsonl` (ATT&CK v20.0), and `data/weaknesses/cwe.jsonl` and `capec.jsonl`	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-11	Confirmed
24	TeamStarWolf, Threat Actors: China and Healthcare Threat Watchlist	/case-studies/THREAT_ACTORS_CHINA.md	2026-11-11	Confirmed

Not opened, so not cited as sources: BeyondTrust's 3 February knowledge article (customer login required), BeyondTrust advisory BT26-05 (error response), and Treasury's December 2024 letter to Congress (not located).

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Healthcare Threat Watchlist, Threat Actors: China, The Ransomware Ecosystem, AI Threats 2026, The Year 2026 in Intrusions, Timeline
- Other 2026 remote-access and edge studies: Able2Shell and the RMM attack surface, The PAN-OS GlobalProtect authentication bypass, The Cisco Catalyst SD-WAN authentication bypass, The Citrix NetScaler zero-days, The Ivanti Connect Secure zero-day chain
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- BeyondTrust platform page, Edge Device Security Reference, Ransomware Defense Reference, Vulnerability Management Reference, Vulnerability Prioritization Reference
- Groups: G1051 Medusa Group, G0125 HAFNIUM, G0027 Threat Group-3390
- Software: S1244 Medusa Ransomware, S0029 PsExec, S0357 Impacket, S0020 China Chopper
- Techniques: T1190 Exploit Public-Facing Application, T1136.002 Domain Account, T1098.007 Additional Local or Domain Groups, T1219.002 Remote Desktop Software, T1505.003 Web Shell
- CAPEC: CAPEC-248, CAPEC-88
- Navigator layers, including this study's layer, beyondtrust-remote-support-cve-2026-1731.json
- The Team Star Wolf Intelligence Hub
- All case studies